

ShopSphere

S2 - Admin Authentication, RBAC and Access Control

Admin Portal

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S2 - Admin Authentication, RBAC and Access Control

Platform: Admin Portal

Application: ShopSphere

Objective: Implement only the admin-web behavior relevant to Admin Authentication, RBAC and Access Control; do not implement customer behavior in this document.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-01	Admin login	Admin	Valid admin identity	Submit credentials, authenticate, establish session	Admin reaches permitted dashboard area.
UC-02	Role-based access	Admin	Authenticated session with role	Open module/call API	Only permitted functionality is available.

3. Detailed Implementation Plan

1. Implement admin login, logout, session restoration and protected routes.
2. Render navigation by permission.
3. Implement forbidden page and session-expiry handling.
4. Verify all roles have expected access.

4. Data / State / Contract Scope

- No direct database changes. Data is accessed through backend APIs.

API / Integration Contract

- Consume the corresponding secured /api/v1 admin/customer operational APIs defined by the backend sprint document.

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Only authorized admin roles can access the feature.
- Admin UI reflects server state and permission boundaries.
- Validation, loading, empty, error and confirmation states are implemented where relevant.
- No customer UI behavior is defined in this document.

7. Test Cases

TC	Scenario	Expected Result
TC-S2-01	Wrong admin password	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-02	Expired token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-03	Customer token on admin API	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

TC	Scenario	Expected Result
TC-S2-04	Role without permission	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-05	Direct forbidden URL	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-06	Revoked session	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-07	Concurrent logout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Backend + DB. That behavior belongs in the separate S2 document for that platform.
- Implementation behavior of Customer Portal. That behavior belongs in the separate S2 document for that platform.